paiement-api — SEPA transfer microservice — RTS 2024/1774 · Internal policy PDS-2 (Banque Kerlann, fictitious)

Banque Kerlann (fictitious) · paiement-api — SEPA transfer microservice

Prepared by: **Attest (AI-assisted)**

Auditor sign-off: **pending (work programme reviewed by Attest CI)**

Owner: **IT department — Payments development team**

Date: **2026-11-04 06:23**

Run: **20261104-062306-50e9**

1. Executive summary

OPINION AT TESTING

Unsatisfactory

Basis for opinion

9 controls tested (9 conclusive) against: RTS 2024/1774 — Article 16: ICT systems acquisition, development and maintenance · Internal policy PDS-2 (Banque Kerlann, fictitious) — secure development. Tests run on 2026-11-04 06:23, environment: Demonstration pre-production. The opinion rests solely on the verdicts of the deterministic test scripts and on the evidence sealed in the audit trail.

Scope limitation: Test scripts drafted by AI and not yet reviewed by an auditor; requirements needing document review or interview are not covered; the opinion applies at the test date only.

9 controls tested	**9** findings	**0** findings closed and verified	**9** open findings
0 human approvals	**33** sensitive data items masked in evidence	**6 min 30 s** audit duration	**$0.653 *** measured AI cost

Critical: 1 · High: 4 · Medium: 4 · Low: 0

Key messages

- 9 findings across 9 controls: 1 critical, 4 high, 4 medium.
- 9 findings remain open, with an action plan, an owner and a due date.

2. Scope and method

Engagement	AUD-20261104-50E9
Entity	Banque Kerlann (fictitious)
System	paiement-api — SEPA transfer microservice
System criticality	Supports critical or important functions (DORA)
Environment	Demonstration pre-production
Owner	IT department — Payments development team
Lead auditor	Attest CI

Date	2026-11-04 06:23
Framework	RTS 2024/1774 — Article 16: ICT systems acquisition, development and maintenance · Internal policy PDS-2 (Banque Kerlann, fictitious) — secure development
Audited target	paiement-api code repository (SEPA transfer microservice)
Work programme	reviewed by an auditor (Attest CI) · runs/studio/20261104-062306-50e9/catalogue.json

In scope

- Source code, configuration and CI pipeline of the repository
- Versioned test datasets

Out of scope

- Dynamic testing (DAST) and penetration testing
- Runtime and production environments
- Git history

Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. Every fix goes through a change request approved by the system owner, applied with a dedicated account, logged, then verified by the same test (DORA 9(4)(e)).
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fixes are drafted by the audit tool itself (self-review threat): closing a finding requires independent approval by the system owner.
- Fictitious entity and data: demonstration.

3. Findings overview

REF.	RULE	TITLE	SEVERITY	TESTED	AFTER	STATUS	DUE DATE
F-01	PDS-2.1	No clear-text secrets in versioned code or config	Critical	Non-compliant		Open	2026-12-04
F-02	PDS-2.2	TLS certificate verification never disabled	High	Non-compliant		Open	2027-02-02
F-03	PDS-2.3	Approved password hashing, no MD5/SHA-1 for security	High	Non-compliant		Open	2027-02-02
F-04	PDS-2.6	Test data declared synthetic	High	Non-compliant		Open	2027-02-02
F-05	PDS-2.6	No production export versioned	High	Non-compliant		Open	2027-02-02
F-06	PDS-2.4	Static security analysis in CI on every change	Medium	Non-compliant		Open	2027-05-03
F-07	PDS-2.5	Dependencies pinned to exact versions	Medium	Non-compliant		Open	2027-05-03

F-08	PDS-2.5	Dependencies audited in CI	Medium	Non-compliant	Open	2027-05-03
F-09	PDS-2.7	Authentication successes and failures logged	Medium	Non-compliant	Open	2027-05-03

4. Detailed findings and controls

F-01 PDS-2.1 No clear-text secrets in versioned code or config

Critical · Non-compliant · Open

CRITERIA

Verify no password, key or token is hard-coded in clear text.

PDS-2.1 · RTS 7(2)

Threshold source: PDS-2.1

> *« Aucun secret (mot de passe, clé, jeton) n'est écrit en clair dans le code source ni dans la configuration versionnée : les secrets viennent d'un coffre ou de variables d'environnement. »*

CONDITION

Observed: `{"hardcoded_matches": 2, "loader_matches": 0, "config_has_hardcoded": true, "config_uses_loader": false, "config_lines": 8}`

Expected: `Zero hard-coded secrets in clear text; secrets only loaded via os.environ or vault client.`

Found 2 hard-coded secret assignments matching password secret token pattern and app config was inspected for environment vault loading.

RISK

Hard-coded secrets allow credential theft and unauthorized transfers.

RECOMMENDATION

Remove clear-text secrets and load them from vault or environment variables.

Due date: 2026-12-04 · Owner: IT department — Payments development team

Test procedure: GET /api/repo/paiement-api/tree to list files, then GET /api/repo/paiement-api/search?q=(?i)(password|passwd|secret|api[_-]?key|token)\s*[:=]\s*['"][^'"]+['"] and q=os\.environ|vault|secrets, then GET /api/repo/paiement-api/file?path=app/config.py to inspect secret handling.



At testing — The screenshot corroborates the test. Screenshot shows 8-line config with hardcoded DB_PASSWORD and JWT_SECRET instead of environment or vault loading. · 3/3 sensitive data items masked (0 spotted by the AI, the rest by the deterministic safety net)

2026-11-04 06:25:45 · SHA-256 f1d137d27ca60583…

F-02 PDS-2.2 TLS certificate verification never disabled

High · Non-compliant · Open

CRITERIA

Verify no outgoing call disables TLS certificate verification.

PDS-2.2 · DORA 9(3)(a), RTS 6(2)(a)

Threshold source: PDS-2.2

CONDITION

Observed: `[{"path": "app/payments.py", "line": 18, "text": " response = requests.post(PSP_URL, json=payload, timeout=TIMEOUT_S, verify=False)"}]`

> *« Tout appel réseau sortant vérifie le certificat TLS du serveur : la vérification n'est jamais désactivée (`verify=False` interdit). »*

Expected: `Zero occurrences of verify=False or unverified SSL context; TLS verification enabled.`
Found TLS verification disabled in file app/payments.py at line 18.

RISK

Disabled TLS verification enables man-in-the-middle interception of SEPA transfers.

RECOMMENDATION

Remove verify=False and enforce default TLS certificate verification.

Due date: 2027-02-02 · Owner: IT department — Payments development team

Test procedure: GET /api/repo/paiement-api/search?q=verify\s*=\s*False and q=requests\.|httpx\.|urllib|ssl\._create_unverified, then GET /api/repo/paiement-api/file?path=<matched file> to confirm context.



At testing — The screenshot corroborates the test. Screenshot shows line 18 of app/payments.py using verify=False in requests.post, confirming disabled TLS verification.
`2026-11-04 06:25:06 · SHA-256 03ffbdd593d56b5c…`

F-03 PDS-2.3 Approved password hashing, no MD5/SHA-1 for security

High · Non-compliant · Open

CRITERIA

Verify passwords use argon2, bcrypt, scrypt or PBKDF2 and MD5/SHA-1 are not used for security.

PDS-2.3 · RTS 6(3) et 6(4)

Threshold source: PDS-2.3

> *« Les mots de passe sont hachés avec argon2, bcrypt, scrypt ou PBKDF2. MD5 et SHA-1 sont interdits pour tout usage de sécurité. »*

CONDITION

Observed: `["app/auth.py:8:return hashlib.md5(password.encode()).hexdigest()"]`
Expected: `Password hashing uses only argon2, bcrypt, scrypt or PBKDF2; zero security use of MD5 or SHA-1.`
Found MD5 or SHA-1 use in production file app/auth.py with no allowed exception.

RISK

Weak hashes allow password recovery and authentication bypass.

RECOMMENDATION

Migrate to argon2, bcrypt, scrypt or PBKDF2 and remove MD5/SHA-1 for security uses.

Due date: 2027-02-02 · Owner: IT department — Payments development team

Test procedure: GET /api/repo/paiement-api/search?q=argon2|bcrypt|scrypt|pbkdf2|passlib|hashlib\.(md5|sha1)\(|hashlib\.sha1|hashlib\.md5 and GET /api/repo/paiement-api/file?path=<matched file> to verify usage context is password hashing.



At testing — The screenshot corroborates the test. The screenshot shows hash_password in app/auth.py using hashlib.md5 for password verification.

`2026-11-04 06:24:36 · SHA-256 9b670c1eafd915cb…`

F-04 PDS-2.6 Test data declared synthetic

High | Non-compliant | Open

CRITERIA

Verify test data is synthetic and declared with synthetic true.

PDS-2.6 · RTS 16(5)(a)

Threshold source: PDS-2.6

> *« Les données de test sont synthétiques et déclarées comme telles (champ `"synthetic": true`) ; aucun export de production n'est versionné. »*

CONDITION

Observed: `{ "export": "production", "date": "2026-09-30", "source": "base clients paiement (prod)", "clients": [ { "nom": "Claire Morel", "email":…`

Expected: `Test fixtures contain "synthetic": true declaration.`

File tests/fixtures/clients_export_prod.json lacks synthetic true declaration.

RISK

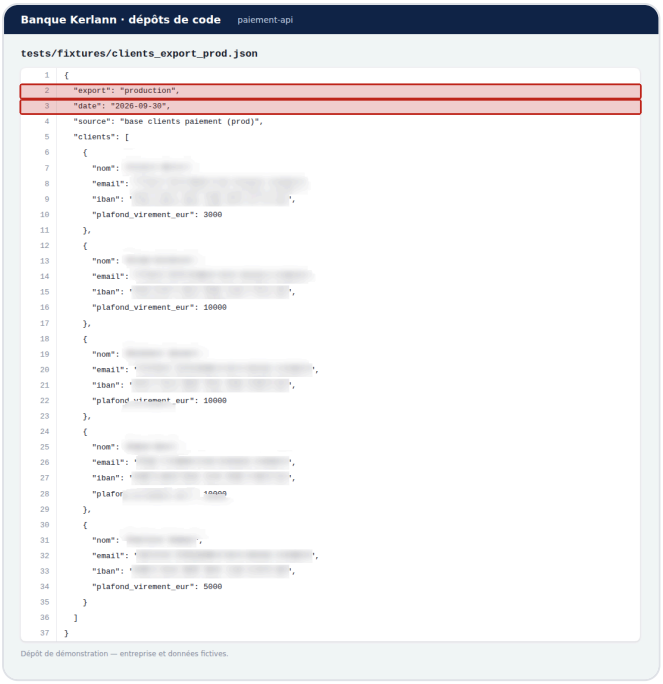
Real production data in tests breaches confidentiality of transfer data.

RECOMMENDATION

Replace test data with synthetic data declared with "synthetic": true.

Due date: 2027-02-02 · Owner: IT department — Payments development team

Test procedure: GET /api/repo/paiement-api/tree to list tests/ fixtures, then GET /api/repo/paiement-api/search?q=synthetic and GET /api/repo/paiement-api/file?path=tests/<fixture file> to verify synthetic true marker.



At testing — The screenshot corroborates the test. The file declares a production export from the prod payment client base with no synthetic true marker. · 15/15 sensitive data items masked (6 spotted by the AI, the rest by the deterministic safety net)
`2026-11-04 06:26:50 · SHA-256 f87bd7695e206358…`

F-05 PDS-2.6 No production export versioned

High | Non-compliant | Open

CRITERIA

Verify no production data export is stored in the repository.

PDS-2.6 · RTS 16(5)(a)

Threshold source: PDS-2.6

> *« Les données de test sont synthétiques et déclarées comme telles (champ `"synthetic": true`) ; aucun export de production n'est versionné. »*

CONDITION

Observed: `{"total_files": 11, "export_files": ["tests/fixtures/clients_export_prod.json", "tests/test_payments.py"], "search_match_count": 2, "evidence_file": "tests/fixt…`

Expected: `Zero versioned files constituting a production data export.`

Found 2 versioned production-export files: tests/fixtures/clients_export_prod.json.

RISK

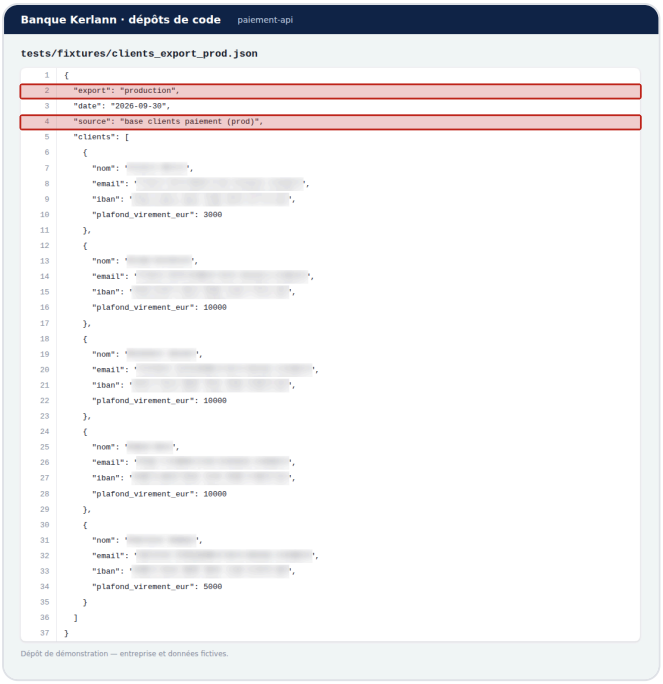
Versioned production exports expose real customer data in non-production.

RECOMMENDATION

Remove any production exports from version control and use synthetic data.

Due date: 2027-02-02 · Owner: IT department — Payments development team

Test procedure: GET /api/repo/paiement-api/tree to list all files and GET /api/repo/paiement-api/search?q=(?i)production|prod_dump|real_data|export_prod to verify no versioned production export or dump file.



At testing — The screenshot corroborates the test. The screenshot shows a versioned file named clients_export_prod.json explicitly marked as a production export. · 15/15 sensitive data items masked (0 spotted by the AI, the rest by the deterministic safety net)
`2026-11-04 06:29:36 · SHA-256 d603feab519b9c27…`

F-06 PDS-2.4 Static security analysis in CI on every change

Medium | Non-compliant | Open

CRITERIA

Verify CI runs bandit, semgrep or CodeQL on every change.

PDS-2.4 · RTS 16(3)

Threshold source: PDS-2.4

> *« La chaîne d'intégration continue exécute une analyse statique de sécurité (bandit, semgrep ou CodeQL) à chaque modification. »*

CONDITION

Observed: `{"workflows_checked": [".github/workflows/ci.yml"], "search_match_count": 0, "has_sast_on_push_pr": false}`

Expected: `CI workflow contains a step invoking bandit, semgrep or CodeQL on push and pull_request.`

No workflow in .github/workflows/ runs bandit, semgrep or CodeQL on push and pull_request.

RISK

Missing SAST lets code vulnerabilities reach production undetected.

RECOMMENDATION

Add bandit, semgrep or CodeQL step to CI on every change.

Due date: 2027-05-03 · Owner: IT department — Payments development team

Test procedure: GET /api/repo/paiement-api/tree to list .github/workflows files, then GET /api/repo/paiement-api/file?path=.github/workflows/<workflow file> and GET /api/repo/paiement-api/search?q=bandit|semgrep|CodeQL|codeql to confirm SAST step on push/pull_request.



At testing — The screenshot corroborates the test. The ci.yml workflow triggers only on push and runs only checkout, setup-python and pytest with no bandit, semgrep or CodeQL step.
`2026-11-04 06:25:03 · SHA-256 cfbb2e4159bb03c3…`

F-07 PDS-2.5 Dependencies pinned to exact versions

Medium | Non-compliant | Open

CRITERIA

Verify all dependencies are pinned to an exact version.

PDS-2.5 · RTS 16(4) et 16(8)

Threshold source: PDS-2.5

> *« Les dépendances sont épinglées à une version exacte (`paquet==version`) et auditées en intégration continue (pip-audit ou équivalent). »*

CONDITION

Observed: `{"dependency_lines": ["flask", "requests>=2.0", "pyjwt==2.8.0"], "non_compliant": ["flask", "requests>=2.0"]}`

Expected: `Every entry in requirements.txt uses == exact pinning.`

Found 2 non-pinned lines among 3 dependencies.

RISK

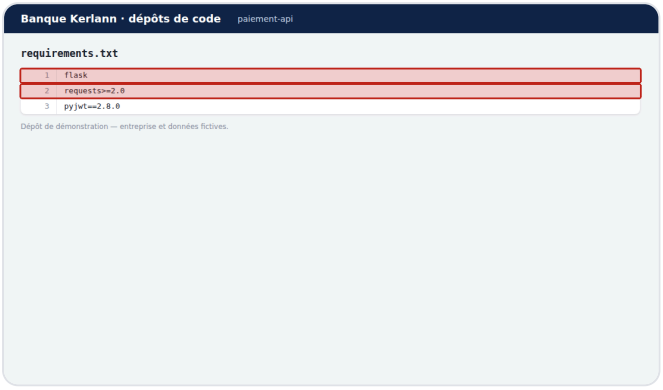
Unpinned dependencies allow untested vulnerable versions to be deployed.

RECOMMENDATION

Pin all dependencies to exact versions with paquet==version.

Due date: 2027-05-03 · Owner: IT department — Payments development team

Test procedure: GET /api/repo/paiement-api/file?path=requirements.txt and verify every dependency line matches paquet==version with no unpinned, wildcard or range specifiers.



At testing — The screenshot corroborates the test. Screenshot shows flask with no version and requests with >= specifier while only pyjwt uses exact pinning.
`2026-11-04 06:26:05 · SHA-256 94071ff0cc3ec301…`

F-08 PDS-2.5 Dependencies audited in CI

Medium | Non-compliant | Open

CRITERIA

CONDITION

Verify dependencies are audited in CI with pip-audit or equivalent.

PDS-2.5 · RTS 16(4) et 16(8)

Threshold source: PDS-2.5

> *« Les dépendances sont épinglées à une version exacte (`paquet==version`) et auditées en intégration continue (pip-audit ou équivalent). »*

Observed: `workflows checked: .github/workflows/ci.yml; no pip-audit|safety|audit-ci|dependabot|osv-scanner found`

Expected: `CI workflow contains pip-audit or equivalent audit step.`

No pip-audit or equivalent audit step found in 1 workflow file(s).

RISK

Unaudited dependencies allow known vulnerabilities into production.

RECOMMENDATION

Add pip-audit or equivalent dependency audit to CI.

Due date: 2027-05-03 · Owner: IT department — Payments development team

Test procedure: GET /api/repo/paiement-api/tree to list .github/workflows files, then GET /api/repo/paiement-api/file?path=.github/workflows/<workflow file> and GET /api/repo/paiement-api/search?q=pip-audit|safety|audit-ci|dependabot|osv-scanner to confirm audit step.



At testing — The screenshot corroborates the test. The workflow shows only checkout, setup-python, install and pytest steps with no dependency audit tool.

`2026-11-04 06:27:44 · SHA-256 9158e3953e996b73…`

F-09 PDS-2.7 Authentication successes and failures logged

Medium · Non-compliant · Open

CRITERIA

Verify the application logs both successful and failed authentications.

PDS-2.7 · RTS 12(2)(c)(i)

Threshold source: PDS-2.7

> *« Les réussites et les échecs d'authentification sont journalisés par l'application. »*

CONDITION

Observed: `{"checked": ["app/auth.py"], "snippet": "\"\"\"Authentification des opérateurs back-office.\"\"\"\nimport hashlib\n\nfrom .db import get_operator\n\n\ndef hash_…`

Expected: `Code contains logging of both authentication success and authentication failure.`

No reviewed app file logs both authentication success and failure.

RISK

Missing auth logs prevent detection of brute-force and account takeover.

RECOMMENDATION

Add logging for both authentication successes and failures.

Due date: 2027-05-03 · Owner: IT department — Payments development team

Test procedure: GET /api/repo/paiement-api/search?q=(?i)auth.*log|log.*auth|login.*(success|fail)|authenticate and GET /api/repo/paiement-api/file?path=<matched app file> to confirm logging of both success and failure paths.



At testing — The screenshot corroborates the test. The login function handles both failure and success paths with returns and no logging calls.

2026-11-04 06:28:30 · SHA-256 657e80f51e1bea04…

Appendices

A. Traceability matrix

REQUIREMENT	RULE	CONTROL	SCRIPT (SHA-256)	RESULT
RTS 7(2)	PDS-2.1	C1 · No clear-text secrets in versioned code or config	8db83beca8af6ed1 · written by AI for this engagement	Non-compliant
DORA 9(3)(a), RTS 6(2)(a)	PDS-2.2	C2 · TLS certificate verification never disabled	c73977b49c845141 · written by AI for this engagement	Non-compliant
RTS 6(3) et 6(4)	PDS-2.3	C3 · Approved password hashing, no MD5/SHA-1 for security	7303fcd9e7022ca1 · written by AI for this engagement	Non-compliant
RTS 16(3)	PDS-2.4	C4 · Static security analysis in CI on every change	0d91fbb136d933d7 · written by AI for this engagement	Non-compliant
RTS 16(4) et 16(8)	PDS-2.5	C5 · Dependencies pinned to exact versions	eee25ca4442b8bcc · written by AI for this engagement	Non-compliant
RTS 16(4) et 16(8)	PDS-2.5	C6 · Dependencies audited in CI	597f52dc7c3a1ac2 · written by AI for this engagement	Non-compliant
RTS 16(5)(a)	PDS-2.6	C7 · Test data declared synthetic	69929a4d729914c4 · written by AI for this engagement	Non-compliant
RTS 16(5)(a)	PDS-2.6	C8 · No production export versioned	dd0ef7b2afa7ce0e · written by AI for this engagement	Non-compliant
RTS 12(2)(c)(i)	PDS-2.7	C9 · Authentication successes and failures logged	f30d64b974dc586d · written by AI for this engagement	Non-compliant

B. Evidence register

FILE			SHA-256
evidence/C1_before.png	C1 · At testing	2026-11-04 06:25:45	f1d137d27ca60583cb9ab6fdeeb5f95fd1610ca96053b4af1fa078191f433317
evidence/C2_before.png	C2 · At testing	2026-11-04 06:25:06	03ffbdd593d56b5c2617e7935507798b8d74d6a1c2264c4c5f0bd6bf9de88b32
evidence/C3_before.png	C3 · At testing	2026-11-04 06:24:36	9b670c1eafd915cb6df201edf42dc67d9cd479c769ad7b5f49bc574e294bd891
evidence/C4_before.png	C4 · At testing	2026-11-04 06:25:03	cfbb2e4159bb03c3141060aef9f46daabbc947f5fddcfe451d46811938fcb0b0
evidence/C5_before.png	C5 · At testing	2026-11-04 06:26:05	94071ff0cc3ec3013b5c4620d989ef9e69def04847069f8c7a03fba625a6574f
evidence/C6_before.png	C6 · At testing	2026-11-04 06:27:44	9158e3953e996b737214ad097196c3e0f4bad638d121409db4398cf4e5de168e
evidence/C7_before.png	C7 · At testing	2026-11-04 06:26:50	f87bd7695e2063588266f0160e61570d959a130f880e25bf156f8012905e9de1

evidence/C8_before.png	C8 · At testing	2026-11-04 06:29:36	d603feab519b9c2747e18ddb985fe13abae028ac459dbb8cdb26de0b430c35b0
evidence/C9_before.png	C9 · At testing	2026-11-04 06:28:30	657e80f51e1bea04d43c9a533ecb37240a389a5499268bc2f297f796c1ef6804

C. AI usage, costs and human oversight

MODEL	CALLS	INPUT TOKENS	OUTPUT TOKENS	IMAGES	COST (USD)
muse-spark-1.3	20	27,590	145,616	0	0.6534
sam-3.1	10	0	0	10	price not published
Total					**0.6534**

Sensitive data (personal data and secrets) in evidence: 6/33 spotted by Muse Spark + SAM, 33/33 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

Safeguards

- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

f4ba0741bc08a8602f8c52404ceb2074b05442c6699ab9687c1aa5539b1ade73

F. Framework coverage

20 requirements read: 11 tested automatically (9 controls; 4 regulation clauses covered through the policy), 9 left to document review, 0 to interviews, 0 rejected for lack of an exact quote. Attest only covers the first group.

REF.	TEXT (VERIFIED QUOTE)	TESTABILITY	CONTROL	
RTS 16(1)	« financial entities shall develop, document and implement a policy governing the acquisition, development, and maintenance of ICT systems. »	document review	0	Existence and content of a governance policy cannot be proven from read-only source code alone.
RTS 16(1)(a)	« identify security practices and methodologies relating to the acquisition, development, and maintenance of ICT systems; »	document review	0	Policy content requires document review and is not visible in the code repository.
RTS 16(1)(c)	« specify measures to mitigate the risk of unintentional alteration or intentional manipulation of the ICT systems during development, maintenance, and deployment. »	document review	0	Required measures are policy statements requiring document review, not code inspection.
RTS 16(2)	« financial entities shall develop, document, and implement an ICT systems' acquisition, development, and maintenance procedure for the testing and approval of all ICT systems prior to their use and after maintenance. »	document review	0	Existence of a testing and approval procedure requires document review beyond the repository.

RTS 16(3)	« the procedure shall contain source code reviews covering both static and dynamic testing, including security testing for internet-exposed systems and applications. »	**tested automatically**	→ PDS-2.4	Static testing part is testable in the repository via CI configuration and is implemented by PDS-2.4.
RTS 16(3)(a)	« identify and analyse vulnerabilities and anomalies in the source code; »	**document review**	0	Identification and analysis activity requires reports and action tracking, not just current code.
RTS 16(3)(b)	« adopt an action plan to address those vulnerabilities and anomalies; »	**document review**	0	An action plan is a governance document not observable in read-only code.
RTS 16(3)(c)	« monitor the implementation of that action plan. »	**document review**	0	Monitoring requires follow-up records and interviews, not testable via code snapshot.
RTS 16(4)	« the procedure shall contain security testing of software packages no later than at the integration phase. »	**tested automatically**	→ PDS-2.5	Integration-phase package testing is implemented by PDS-2.5 and visible in CI and dependencies.
RTS 16(5)(a)	« non-production environments only store anonymised, pseudonymised, or randomised production data; »	**tested automatically**	→ PDS-2.6	Use of synthetic versus production data in versioned fixtures is testable via repository search.
RTS 16(5)(b)	« financial entities are to protect the integrity and confidentiality of data in non-production environments. »	**document review**	0	Protection controls for environments require configuration and process review beyond code.
RTS 16(7)	« the procedure shall include controls to protect the integrity of source code of ICT systems that are developed in-house or by an ICT third-party service provider. »	**document review**	0	Source code integrity controls require procedure and branch protection review, not code content alone.
RTS 16(8)	« proprietary software and, where feasible, the source code provided by ICT third-party service providers, as well as source code coming from open-source projects, are to be analysed and tested in accordance with paragraph »	**tested automatically**	→ PDS-2.5	Dependency analysis and testing before deployment is implemented by PDS-2.5 and visible in CI.
PDS-2.1	« Aucun secret (mot de passe, clé, jeton) n'est écrit en clair dans le code source ni dans la configuration versionnée : les secrets viennent d'un coffre ou de variables d'environnement. »	**tested automatically**	1	Clear-text secrets are directly searchable in repository files and config via the read-only gateway.
PDS-2.2	« Tout appel réseau sortant vérifie le certificat TLS du serveur : la vérification n'est jamais désactivée (`verify=False` interdit). »	**tested automatically**	1	TLS verification disabling is searchable as code pattern verify=False in the repository.
PDS-2.3	« Les mots de passe sont hachés avec argon2, bcrypt, scrypt ou PBKDF2. MD5 et SHA-1 sont interdits pour tout usage de sécurité. »	**tested automatically**	1	Hashing libraries and forbidden hash functions are searchable in Python source.
PDS-2.4	« La chaîne d'intégration continue exécute une analyse statique de sécurité (bandit, semgrep ou CodeQL) à chaque modification. »	**tested automatically**	1	CI workflow files in .github/workflows are readable via the gateway and show SAST tools.

PDS-2.5	« Les dépendances sont épinglées à une version exacte (`paquet==version`) et auditées en intégration continue (pip-audit ou équivalent). »	**tested automatically**	2	requirements.txt pinning and CI audit steps are directly readable via tree, file and search.
PDS-2.6	« Les données de test sont synthétiques et déclarées comme telles (champ `"synthetic": true`) ; aucun export de production n'est versionné. »	**tested automatically**	2	Test fixtures and versioned files are listable and searchable for synthetic marker via the gateway.
PDS-2.7	« Les réussites et les échecs d'authentification sont journalisés par l'application. »	**tested automatically**	1	Application logging calls for authentication outcomes are searchable in source code.